Security & Privacy Disclosure, Final Report

Crunchyroll Android (com.crunchyroll.crunchyroid)

A hardcoded Braze API key routes EU subscriber CRM data to a named US data center, a full 491-class Razorpay India payment SDK ships inside the same EU-distributed build with no Art. 44 safeguard, microphone access is declared on a passive anime-streaming service whose audience includes minors, and Datadog session-replay telemetry initializes before the app's own consent platform can act, unresolved through 109 days and a 19-day-overdue embargo, with ten messages answered by zero replies of any kind, not even an automated one

PUBLIC DISCLOSURE, 17 OCTOBER 2026 — EMBARGO REACHED 28 SEPTEMBER 2026, FOUR FINDINGS REMAIN UNADDRESSED

Target	Crunchyroll LLC / Sony Pictures Entertainment (NYSE: SONY)
Package	com.crunchyroll.crunchyroid
Platform Audited	Android, static analysis of the production APK (50,118 smali classes)
Initial Disclosure (R1)	2026-06-30 (REF CRUNCHYROLL-2026-R1-001)
Disclosure / Embargo Date	2026-09-28
Report Published	2026-10-17
Overall Severity	CRITICAL
Findings	4 (1 Critical, 3 High)
Correspondence	10 messages sent by RFI-IRFOS to privacy@crunchyroll.com and legal@crunchyroll.com over 74 days, 0 replies of any kind ever received, no bounce, no automated acknowledgment, no human reply
Authorities CC'd	Austrian Datenschutzbehoerde (DSB) · European Data Protection Supervisor (EDPS)

security@rfi-irfos.com • rfi-irfos.com

ZVR 1015608684 • GISA 39261441 • UID ATU83405245 • Steuernummer 68 696/8736 • Graz, Austria

Contents

1 Executive Summary 4

2 Subject & Operator Context 5

3 Engagement Summary 5

4 Findings 5

4.1 C1: Hardcoded Firebase and Braze CRM keys, with an explicit US data-routing endpoint for EU subscriber CRM data 5

4.2 H1: RECORD_AUDIO permission declared on a passive anime-streaming and manga-reading service with a large minor audience 6

4.3 H2: Full 491-class Razorpay India payment SDK shipped in the globally distributed EU build, no EU adequacy decision for India 6

4.4 H3: Datadog RUM and Firebase auto-initialize before consent, despite an implemented OneTrust consent management platform 7

5 Impact Analysis 7

6 The Complete Chain: Ten Messages, Seventy-Four Days, Zero Replies of Any Kind 8

7 Data Protection – Article by Article 8

8 Regulatory & Legal Landscape 9

9 Indicators of Compromise 9

10 Disclosure Timeline & Outcome 10

11 Residual Risk & Recommendations 10

Executive Summary

Crunchyroll is the anime, manga, and streaming subscription service operated by Crunchyroll LLC, a subsidiary of Sony Pictures Entertainment (NYSE: SONY, roughly $90 billion market capitalization). A root-level static analysis of the production Android binary (com.crunchyroll.crunchyroid, 50,118 smali classes) found four findings, one CRITICAL and three HIGH.

A Firebase API key, a live production Firebase Realtime Database URL, and a Braze CRM API key are all hardcoded in every installed copy of the app. The Braze key is paired with an explicit custom endpoint, sdk.iad-03.braze.com, IAD denoting Washington Dulles, Virginia, a deliberate architectural choice to route EU subscriber behavioral and CRM data to United States infrastructure with no apparent Art. 44-49 transfer safeguard (C1). Separately, the app ships a full 491-class Razorpay SDK, an Indian payment gateway headquartered in Bangalore; India has no EU adequacy decision under Art. 45, and a payment SDK of this scale indicates a genuine integration, not a dormant stub, meaning Crunchyroll appears to ship one global APK build carrying Razorpay's full data-processing capability into every EU subscriber's device regardless of whether it is actually invoked for EU transactions (H2). The app also declares RECORD_AUDIO, a permission with no apparent purpose on a passive media-streaming and manga-reading service, a concern sharpened by anime's well-documented large minor audience share (H1). Finally, although Crunchyroll has implemented OneTrust as a consent management platform, a genuinely positive finding, Datadog's Real User Monitoring content provider and Firebase both auto-initialize before any consent signal is captured, meaning session-replay-grade interaction telemetry begins collecting ahead of the very consent mechanism the company built to govern it (H3).

RFI-IRFOS disclosed these findings on 30 June 2026 to privacy@crunchyroll.com and legal@crunchyroll.com, CC press@crunchyroll.com, the Austrian Datenschutzbehoerde, and the European Data Protection Supervisor, stating an embargo date of 28 September 2026. Over the following 74 days RFI-IRFOS sent nine further messages restating the findings, the three direct questions, and the days elapsed. Across ten messages in total, not one reply of any kind was ever received, no bounce, no automated acknowledgment, no human reply, from either address or from Sony Pictures Entertainment at any level.

ID	Severity	Title
C1	CRITICAL	Hardcoded Firebase and Braze CRM keys, with an explicit US data-routing endpoint for EU subscriber CRM data
H1	HIGH	RECORD_AUDIO permission declared on a passive anime-streaming and manga-reading service with a large minor audience
H2	HIGH	Full 491-class Razorpay India payment SDK shipped in the globally distributed EU build, no EU adequacy decision for India
H3	HIGH	Datadog RUM and Firebase auto-initialize before consent, despite an implemented OneTrust consent management platform

Subject & Operator Context

Crunchyroll is a subscription anime, manga, and simulcast streaming service operated by Crunchyroll LLC, acquired by and operated under Sony Pictures Entertainment, itself a subsidiary of Sony Group Corporation (NYSE: SONY). The service's subscriber base and the broader anime fandom it serves include a substantial proportion of minors, a demographic fact this report treats as directly relevant context for the RECORD_AUDIO and consent-timing findings below.

Engagement Summary

RFI-IRFOS sent the initial disclosure on 30 June 2026 to privacy@crunchyroll.com and legal@crunchyroll.com, CC press@crunchyroll.com, the Austrian Datenschutzbehoerde, and the European Data Protection Supervisor, stating an embargo date of 28 September 2026 under REF CRUNCHYROLL-2026-R1-001. RFI-IRFOS followed up on 6 July, 17 July, 23 July, 31 July, 9 August, 15 August, 24 August, 31 August, and 12 September 2026, ten messages in total, each restating the open findings, the three direct questions on RECORD_AUDIO's purpose, the Razorpay transfer mechanism, and the Braze EU-to-US routing and Datadog pre-consent gap, and the days elapsed. No bounce was ever recorded against either address, no automated acknowledgment of any kind was ever received, and no human reply ever arrived. The final message in the record, sent 12 September 2026, states plainly that 74 days and eight messages had passed without even an automated response; it too went unanswered.

Findings

C1: Hardcoded Firebase and Braze CRM keys, with an explicit US data-routing endpoint for EU subscriber CRM data

CRITICAL (CVSS v4.0 AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:L/VA:N/SC:N/SI:N/SA:N, 8.0) — EU subscriber behavioral and CRM data routed by design to a named US data center, no Art. 44 safeguard apparent

```
google_api_key: [REDACTED IN PUBLIC REPORT -- disclosed privately to Crunchyroll in R1
    ]
firebase_database_url: [REDACTED IN PUBLIC REPORT -- disclosed privately to
    Crunchyroll in R1]
com_braze_api_key: [REDACTED IN PUBLIC REPORT -- disclosed privately to Crunchyroll in
     R1]
com_braze_custom_endpoint: sdk.iad-03.braze.com
  (IAD = Washington Dulles, Virginia, USA)

Transfer mechanism documented for this EU-to-US routing: none identified
```

Impact: A Firebase API key and a live production Firebase Realtime Database URL are hardcoded in every installed copy of the production APK, alongside a Braze CRM API key paired

with an explicit custom endpoint, sdk.iad-03.braze.com, IAD denoting Washington Dulles, Virginia. Braze handles push notifications, in-app messaging, behavioral analytics, and user segmentation for Crunchyroll's subscriber base. Naming a specific US endpoint rather than a region-agnostic one is a deliberate architectural choice to route EU subscriber CRM data to the United States, and no Art. 44-49 GDPR transfer mechanism is apparent for this flow.

H1: RECORD_AUDIO permission declared on a passive anime-streaming and manga-reading service with a large minor audience

---

HIGH (CVSS v4.0 AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N, 5.3) — RFI-IRFOS blast-radius escalation: raised from an ordinary over-collection finding to HIGH because the undisclosed purpose sits on a platform with a demonstrably large minor audience, not because active microphone capture was observed

```
<uses-permission android:name="android.permission.RECORD_AUDIO"/>

Declared purpose in app's own Art. 13 disclosure: none located
Product category: passive media streaming, manga reading, subscription management
```

Impact: The app declares the RECORD_AUDIO permission. Crunchyroll's product, anime streaming, manga reading, and premium subscription management, has no obvious feature requiring microphone access; if the permission backs voice search, Chromecast control, or another audio-interaction feature, that purpose and its legal basis are not disclosed anywhere RFI-IRFOS could locate under Art. 13. This matters more than a routine over-collection flag because anime fandom demographics are well documented to include a substantial proportion of minors, and an undisclosed audio-capture capability sitting unexplained on a platform with that audience composition is a materially different risk than the same gap on an adult-oriented product.

H2: Full 491-class Razorpay India payment SDK shipped in the globally distributed EU build, no EU adequacy decision for India

---

HIGH (CVSS v4.0 AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N, 6.5) — a full-scale Indian payment-processing SDK carried into every EU subscriber's device with no documented transfer safeguard

```
com/razorpay/* -- 491 smali classes
Operator: Razorpay Software Pvt. Ltd., Bangalore, India
EU adequacy decision for India (Art. 45 GDPR): none
Build segmentation observed: single global APK, no regional SDK exclusion
```

Impact: The production APK includes 491 smali classes under com/razorpay, a complete SDK integration for Razorpay Software Pvt. Ltd., a payment gateway headquartered in Bangalore, India. India has no EU adequacy decision under Art. 45 GDPR. A 491-class footprint indicates genuine integration depth, not a dormant or unused library. The presence of this full SDK inside a single, globally distributed APK build, rather than a regionally segmented

one, means every EU subscriber's installed app carries Razorpay's complete data-processing capability regardless of whether their own transactions are ever routed through it. If EU subscriber payment data is in fact processed via Razorpay's infrastructure at any point, this constitutes a third-country transfer requiring an Art. 44-49 safeguard (Standard Contractual Clauses, binding corporate rules, or equivalent), and no such mechanism is disclosed.

H3: Datadog RUM and Firebase auto-initialize before consent, despite an implemented OneTrust consent management platform

HIGH (CVSS v4.0 AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N, 5.3) — session-replay-grade interaction telemetry begins before the app's own consent mechanism can act

```
com.datadog.android.rum.DdRumContentProvider -- auto-init ContentProvider
com.google.firebase.provider.FirebaseInitProvider -- initOrder=100
com.onetrust.otpublishers -- OneTrust CMP (present, positive finding)

Consent signal captured before Datadog/Firebase init: no
```

Impact: Crunchyroll has implemented OneTrust (com.onetrust.otpublishers) as a consent management platform, a genuinely positive architectural choice noted here on its own merits. Despite that, Datadog's Real User Monitoring content provider (com.datadog.android.rum.DdRumContentProvider) and Firebase's own content provider (initOrder=100) both auto-initialize at process start, before any consent signal has been captured. Datadog RUM captures user interactions, session flow, tap patterns, and performance data; these observations begin before the user has made any consent choice, which is the specific sequencing Art. 7 GDPR requires consent to precede, not follow.

Impact Analysis

C1 is the most severe finding in this report because it is not an accident of careless configuration but a named, deliberate routing choice: sdk.iad-03.braze.com does not merely happen to resolve to US infrastructure, it is addressed to a specific Virginia data center by design. H2 compounds the same transfer-governance gap in a different direction, a full-scale Indian payment SDK riding along in every EU subscriber's build regardless of whether it is invoked for their own transaction. H1 and H3 are more conventional gaps, an unexplained sensitive permission and a pre-consent telemetry initialization, but both sit on a platform whose own positive step, implementing OneTrust, makes the surrounding gaps more visible rather than less: a company that built a consent platform but let two SDKs start ahead of it, and a company whose audience skews toward minors but ships an unexplained audio-capture permission, has already shown it knows the standard it is not meeting.

What ties all four findings together procedurally is the same failure pattern documented elsewhere in this disclosure series: ten messages, sent to two named, functioning addresses over 74 days, produced not a single reply of any kind, not even an automated one. Sony Pictures Entertainment's own privacy and legal contact points for this service never engaged with the disclosure at all.

The Complete Chain: Ten Messages, Seventy-Four Days, Zero Replies of Any Kind

Step 1 – Disclosure sent: RFI-IRFOS sends the full findings report on 30 June 2026 to privacy@crunchyroll.com and legal@crunchyroll.com, CC press@crunchyroll.com, the Austrian Datenschutzbehoerde, and the EDPS, stating an embargo date of 28 September 2026.

Step 2 through 9 – Eight follow-ups, identical outcome: RFI-IRFOS sends further messages on 6 July, 17 July, 23 July, 31 July, 9 August, 15 August, 24 August, and 31 August 2026, each restating the three direct questions and the days elapsed. No bounce is ever recorded. No automated acknowledgment of any kind is ever received. No human reply ever arrives.

Step 10 – Final follow-up: On 12 September 2026, 74 days after the original disclosure and eight follow-ups in, RFI-IRFOS sends a tenth message stating plainly that not even an automated response had ever been received. It too goes unanswered.

Step 11 – Embargo reached and passed: The embargo, stated once on 30 June 2026 and never revised, passes on 28 September 2026 with all four findings unaddressed.

Step 12 – Publication: This report publishes 19 days after the embargo date. Across 109 days and ten messages sent to two functioning, non-bouncing addresses, the correspondence record contains zero replies of any kind.

Data Protection – Article by Article

Art. 32(1)(b), Art. 25, Art. 44-49 GDPR – Security of processing, data protection by design, and general principle for transfers: C1's Braze EU-to-US routing to a named Virginia endpoint has no documented transfer safeguard.

Art. 5(1)(c), Art. 13, Art. 8 GDPR – Data minimisation, transparency, and conditions for children's data: H1's RECORD_AUDIO permission has no disclosed purpose, on a platform with a substantial minor audience share.

Art. 44-49, Art. 28, Art. 13 GDPR – Third-country transfer, processor agreements, and transparency: H2's Razorpay India integration has no documented Art. 44-49 safeguard and is not named as a recipient.

Art. 7 GDPR – Conditions for consent: H3's Datadog RUM and Firebase both initialize before any consent signal is captured, despite OneTrust's presence.

Regulatory & Legal Landscape

Crunchyroll LLC operates as a subsidiary of Sony Pictures Entertainment, itself part of Sony Group Corporation (NYSE: SONY). The Austrian Datenschutzbehoerde and the European Data Protection Supervisor were both CC'd on the original disclosure and every subsequent follow-up, informed under GDPR Art. 83(2)(b).

Fine exposure under GDPR: Art. 83(5) applies to the Art. 44-49 transfer issues in C1 and H2 and the Art. 8 children's-data issue in H1, up to EUR 20,000,000 or 4% of total worldwide annual turnover, a figure that for a Sony Group subsidiary is measured against Sony's own global turnover. Art. 83(4) applies to the Art. 32, 25, and 7 issues in C1 and H3, up to EUR 10,000,000 or 2% of total worldwide annual turnover. A company at this scale receiving ten written disclosures over 74 days and responding to none of them, not even with an automated acknowledgment, is itself a fact a regulator is likely to weigh alongside the four technical findings.

Indicators of Compromise

The following identifiers, SDK packages, and manifest declarations were extracted from the production APK via static analysis only. No Crunchyroll, Sony, Braze, Razorpay, or Datadog servers, accounts, or infrastructure were probed.

```
C1 -- google_api_key: [REDACTED IN PUBLIC REPORT -- disclosed privately to Crunchyroll
      in R1]
   firebase_database_url: [REDACTED IN PUBLIC REPORT -- disclosed privately to
    Crunchyroll in R1]
   com_braze_api_key: [REDACTED IN PUBLIC REPORT -- disclosed privately to Crunchyroll
      in R1]
   com_braze_custom_endpoint: sdk.iad-03.braze.com

H1 -- android.permission.RECORD_AUDIO

H2 -- com/razorpay/* , 491 smali classes

H3 -- com.datadog.android.rum.DdRumContentProvider
   com.google.firebase.provider.FirebaseInitProvider (initOrder=100)
   com.onetrust.otpublishers (OneTrust CMP, present)
```

Disclosure Timeline & Outcome

2026-06-30 Initial disclosure sent to privacy@crunchyroll.com and legal@crunchyroll.com , CC press@crunchyroll.com, Austrian DSB, EDPS. Embargo stated as 2026-09-28. REF CR UNCHYROLL-2026-R1-001.

2026-07-06, 2026-07-17, 2026-07-23, 2026-07-31, 2026-08-09, 2026-08-15, 2026-08-24, 2026-08-31 Eight follow-up messages, each restating the open findings and the three direct questions. No bounce, no automated acknowledgment, no human reply, at any point.

2026-09-12 Final follow-up, 74 days since the original disclosure, explicitly noting zero replies of any kind received across eight prior messages. No reply follows.

2026-09-28 Embargo date reached, as stated once on 2026-06-30 and never revised. Correspondence record: ten RFI-IRFOS messages, zero replies of any kind.

2026-10-17 This report published, 19 days after the embargo date. All four findings confirmed unaddressed on the basis of the correspondence record.

Residual Risk & Recommendations

C1 – Immediate: route Braze CRM traffic for EU subscribers through an EU-region endpoint or document a Standard Contractual Clause (or equivalent Art. 44 safeguard) for the existing US routing, and rotate the hardcoded Firebase and Braze keys found in the production build.

H1 – Immediate: either remove RECORD_AUDIO if unused, or disclose its specific purpose and legal basis under Art. 13, with particular attention to the Art. 8 safeguards applicable given the platform's minor-audience share.

H2 – Near-term: document an Art. 44-49 transfer mechanism for any EU subscriber payment data that transits Razorpay's infrastructure, or build a regionally segmented APK that excludes the Razorpay SDK from EU distribution entirely.

H3 – Near-term: gate Datadog RUM and Firebase initialization behind the OneTrust consent decision already implemented elsewhere in the app, closing the sequencing gap between the consent platform's presence and its actual enforcement order.

Across all findings: establish a monitored intake path for security and data-protection disclosures sent to privacy@crunchyroll.com and legal@crunchyroll.com. Ten messages over 74 days produced zero responses of any kind from a company at Sony's scale, a process failure worth correcting independently of the four technical findings in this report.

RFI-IRFOS security@rfi-irfos.com • rfi-irfos.com

ZVR 1015608684 • GISA 39261441 • UID ATU83405245 • Steuernummer 68 696/8736 • Elisabethinergasse 25/10, 8020 Graz, Austria All findings derive from static analysis of the published application using publicly available tooling. No Crunchyroll, Sony, Braze, Razorpay, or Datadog servers, accounts, or infrastructure were probed. Technical evidence is archived under chain of custody and will be provided to regulatory authorities on request. Research conducted under ISO/IEC 29147, the freedom of scientific research (Art. 17 StGG) and GDPR Art. 89. REF CRUNCHYROLL-2026-R1-001.